

Manual 52 — Cibersegurança de IA: ciclo de vida seguro, OWASP e MITRE ATLAS

Fonte controlada de publicação — Português (Brasil)

Data de verificação: 1 de setembro de 2026

Objetivo

Este manual estabelece um modelo prático de cibersegurança para sistemas de IA ao longo de projeto, desenvolvimento, integração, implantação, operação, mudança e desativação. IA generativa, RAG e IA agêntica são tratadas como sistemas com fronteiras de confiança, identidades, ferramentas, fluxos de dados e caminhos de ataque específicos.

Disciplina de fontes

OWASP GenAI e Agentic são orientações comunitárias de segurança. MITRE ATLAS é uma base viva de conhecimento adversarial. NIST AI RMF 1.0 e NIST AI 600-1 são referências voluntárias de gestão de riscos. Nenhuma delas é apresentada como certificação legal ou prova de conformidade regulatória.

AC-01 — Inventário de ativos e dependências de IA

Inventariar modelos, APIs, agentes, repositórios RAG, pipelines, ferramentas, identidades, segredos, orquestração, hospedagem e terceiros; registrar responsável, finalidade, versão, dados, permissões e estado.

AC-02 — Arquitetura de fronteiras de confiança

Documentar limites entre usuários, conteúdo não confiável, prompts, instruções de sistema, runtime, RAG, ferramentas, agentes, serviços externos e sistemas privilegiados.

AC-03 — Injeção de prompt direta e indireta

Impedir que conteúdo não confiável adquira autoridade de instrução. Separar política confiável de conteúdo recuperado, validar chamadas de ferramentas, restringir ações e testar caminhos de injeção indireta.

AC-04 — Envenenamento de RAG/fontes

Controlar aprovação, proveniência, ingestão, autorização, integridade, atualidade e recuperação. Testar fontes envenenadas, não autorizadas, obsoletas e enganosas.

AC-05 — Divulgação e exfiltração de dados sensíveis

Proteger prompts, contexto, dados RAG, saídas, logs e respostas de ferramentas com autorização, minimização, filtragem, monitoramento e testes de vazamento.

AC-06 — Tratamento inseguro de saídas

Tratar a saída do modelo como não confiável quando enviada para shells, interpretadores, SQL, templates, navegadores, APIs ou automação. Validar, parametrizar, isolar e aprovar operações consequentes.

AC-07 — Agência excessiva e abuso de ferramentas

Limitar ferramentas, permissões, transações, autonomia e recursos. Exigir aprovação humana quando necessário e manter rastreabilidade atribuível.

AC-08 — Identidade e delegação de agentes

Usar identidades atribuíveis, credenciais de escopo limitado e fronteiras explícitas de delegação. Reavaliar autorização em cada salto entre agentes e ferramentas.

AC-09 — Segurança de segredos e credenciais

Usar gestão de segredos e credenciais de curta duração quando viável, com rotação e revogação rápida. Não incorporar segredos duradouros em prompts ou memória.

AC-10 — Cadeia de suprimentos de modelo/dados/software

Rastrear versões de modelo/provedor, bibliotecas, contêineres, datasets, plugins, ferramentas e dependências. Aplicar controles de integridade e gatilhos de revalidação.

AC-11 — Envenenamento de modelos e dados

Proteger dados de treinamento, ajuste, avaliação e recuperação contra modificação não autorizada ou conteúdo malicioso. Preservar proveniência e integridade.

AC-12 — Extração, roubo e abuso do modelo

Aplicar autenticação, autorização, limites de uso e monitoramento de anomalias conforme exposição e valor. Detectar scraping, enumeração e sondagem repetida de fronteiras.

AC-13 — Esgotamento de recursos / negação de serviço

Controlar tokens, computação, recursão, chamadas de ferramenta, APIs e transações por meio de quotas, timeouts, limites de recursão e circuit breakers.

AC-14 — Monitoramento e detecção de segurança

Coletar telemetria de autenticação, uso de ferramentas, negações de política, prompts/ações anômalas, eventos RAG, mudanças de modelo e ações de contenção.

AC-15 — Testes adversariais e red teaming

Testar injeção de prompt, envenenamento RAG, abuso de ferramentas, vazamento de dados, escalonamento de privilégios, execução insegura, abuso do modelo, adulteração de supply chain e falhas de contenção.

AC-16 — Gestão de vulnerabilidades e mudanças

Rastrear vulnerabilidades e tratar mudanças de modelo, provedor, ferramenta, permissão, política, fonte RAG ou orquestração como possíveis gatilhos de revalidação.

AC-17 — Segurança de terceiros de IA

Avaliar provedores externos quanto a segurança, identidade, tratamento de dados, notificação de mudanças, incidentes, continuidade, subcontratados e acesso a evidências.

AC-18 — Resposta a incidentes de IA

Preservar versão de modelo/provedor, prompts, contexto, logs RAG/ferramenta/agente, identidades, exposição de dados, detecções e evidências de contenção.

AC-19 — Contenção, rollback e desativação emergencial

Manter capacidade testada para desativar agentes/ferramentas, revogar credenciais, isolar ambientes, bloquear endpoints e restaurar configuração segura.

AC-20 — Desativação segura

Revogar credenciais, remover acessos, arquivar evidências necessárias, aplicar retenção/exclusão, descomissionar integrações e atualizar inventário.

Cenários adversariais obrigatórios

1. Injeção indireta por RAG.
2. Uso de ferramenta por agente superprivilegiado.
3. Mudança de versão do modelo pelo provedor.
4. Exfiltração de dados via RAG.
5. Execução insegura de saída.
6. Abuso de delegação entre agentes.
7. Adulteração de modelo ou artefato na cadeia de suprimentos.
8. Jailbreak combinado com invocação de ferramentas.
9. Envenenamento de dados de treinamento/avaliação.
10. Resposta a incidente com telemetria incompleta.

Cada cenário deve gerar evidências de prevenção, detecção, contenção, recuperação, revalidação e escalonamento. Não há aprovação apenas porque o dano não ocorreu.

Registro mínimo de evidências

- AC-E01 inventário de ativos e dependências.
- AC-E02 modelo de ameaças e fronteiras de confiança.
- AC-E03 pacote de testes de prompt/RAG.
- AC-E04 desenho de autorização e delegação de agentes.
- AC-E05 avaliação da cadeia de suprimentos e integridade.
- AC-E06 resultados adversariais/red team.
- AC-E07 mapa de telemetria e detecção.
- AC-E08 pacote de evidências de incidentes.
- AC-E09 registro de mudanças e revalidação.
- AC-E10 teste de recuperação e contenção.

Método de crosswalk

Cada linha registra controle empresarial → relação OWASP → relação MITRE ATLAS quando aplicável → apoio NIST → evidência → limitações → risco residual. O Manual 46 fornece a espinha dorsal de governança de IA; o Manual 51 fornece identidade, autonomia, limites de ação, autoridade delegada e responsabilidade humana; o Manual 52 adiciona modelagem adversarial, detecção, red teaming, contenção técnica e evidência de incidentes.

Regra de liberação

Um controle não é considerado eficaz apenas porque existe documentação. São necessárias evidências de implementação, teste, tratamento de exceções e disposição do risco residual. Mudanças materiais de fonte ou plataforma exigem reavaliação.